



400-650-7088

Tong**NCS** V2.0

安全加固手册

版本：2043A01

2025年09月

声明

版权

Copyright ©2025北京东方通科技股份有限公司或其关联公司（以下简称“东方通”）。保留所有权利。

版权声明

- 本文档的所有权和知识产权归属于东方通所有。
- 除非另有明确约定，东方通不授予任何明示或暗示的许可或权利，使用者不得以任何方式将本文档中的任何内容用于商业目的。
- 东方通对本文档享有版权。本文档的所有内容，包括但不限于文字、图像、图表、图标、示意图、屏幕截图等，均受版权法和国际版权条约的保护。
- 未经东方通明确授权，任何人不得对本文档以任何形式复制、修改、传播、分发、展示或进行衍生创作。

商标声明

- **东方通**、**TongTech** 标识以及其他相关东方通图形、徽标、服务名称和商标（以下统称为“东方通商标”）是东方通或其关联公司的注册商标或商标。
- 未经东方通明确授权，任何人不得以任何方式使用、复制或展示东方通商标。此外，未经东方通事先书面同意，不得将东方通商标与其他商标、标识或徽标进行混淆、链接或结合使用。
- 除非另有明确约定，本商标声明不授予任何明示或暗示的许可或权利，对东方通商标的使用须获得东方通的明确授权。
- 本文档提及的所有其他商标、标识、徽标或产品名称均为其各自所有者的财产，并可能受其各自的商标法保护。

免责声明

请在使用东方通产品之前仔细阅读本免责声明，并根据自身情况判断是否继续使用。如有任何问题，请联系我们的客户支持团队。

- 本产品的使用是基于用户自己的判断和风险评估。本文档仅作为使用指导，不对使用本产品所产生的结果做任何明示或暗示的担保。
- 东方通不对用户未按照本文档中的指导正确使用东方通产品而导致的任何损失或损害承担责任；
- 本文档可能会包含第三方提供的内容、链接或资源，这些内容由第三方自行负责。东方通对于这些内容的准确性、完整性、合法性或可靠性不承担责任。用户在使用这些内容时应自行判断和承担风险。
- 由于产品版本升级或其他原因，本文档内容会不定期更新。东方通保留在不事先通知用户的情况下随时对文档进行修改、更新或中止的权利。

如需获取有关东方通产品的许可或使用权，请联系东方通或授权代理商。任何违反本声明的行为将受到适用法律的追究。

版本变更说明

本手册的更新是累积的。因此，最新的手册版本包含对以前版本所做的所有更改。

文档版本	适用产品版本	更新内容	更新日期
2043A01	2.0.4.3	修改“声明”中的版权信息。	2025-09
2042_P1A01	2.0.4.2_P1	无	2025-08
2042A01	2.0.4.2	无	2025-06
2041A01	2.0.4.1	无	2024-12
2040A01	2.0.4.0	无	2024-10
2030A01	2.0.3.0	无	2024-04
2020A01	2.0.2.0	无	2023-12
2010A01	2.0.1.0	首次发布。	2023-10

前言

阅读前注意事项

通过阅读本文档，您确认并同意自行承担因未具备必要专业背景 and 知识而导致的任何风险或后果。在使用本文档中提供的信息和指南时，请始终谨慎，并在必要时寻求专业人士建议和指导。

- 适用对象

本文档主要适用于使用本产品的系统管理员阅读，部分内容同样适用于基于本产品进行应用开发或应用部署的人员阅读。

- 专业背景

本文内容可能涉及到操作系统、服务器硬件、网络等相关领域的知识。请确保您具备相关背景 and 知识，以便更好地理解 and 应用本手册的内容。

- 技能要求

为了能够充分理解 and 应用本文档的内容，建议您具备如下技能：

- Linux 操作系统基本操作；
- 熟悉 TongNCS 的运维管理；
- 熟悉 TongNCS 运行的配套软件，如数据库。

- 术语和概念

本文档可能使用一些专业术语和概念。请确保您熟悉这些术语和概念，或者有能力查阅相关资料以便进一步理解。

- 实践经验

为了最大程度地受益于本文档，建议您具备一定实践经验。这将帮助您更好地应用文档中的操作指南 and 建议。

请注意，本文档不适用于没有相关专业背景 and 知识的用户。如果您对本文档的内容 or 所需背景有任何疑问，请在使用之前咨询相关专业人士 or 寻求额外的支持。

用户手册集

TongNCS 为您提供如下用户使用手册。

编号	用户手册	说明
1	001_TongNCS_V2.0产品安装手册	详细介绍了在单机环境、Docker 环境以及 K8s 环境下快速安装 TongNCS。
2	002_TongNCS_V2.0产品使用手册	详细介绍了 TongNCS 详细功能使用说明。
3	003_TongNCS_V2.0Java Client 开发手册	详细介绍 Java 研发人员使用 TongNCS 提供的 Java Client 开发工具包进行开发。

编号	用户手册	说明
4	004_TongNCS_V2.0Spring 开发手册	详细介绍 Java 研发人员使用 TongNCS 提供的 Spring 开发工具包进行开发。
5	005_TongNCS_V2.0SpringBoot 开发手册	详细介绍 Java 研发人员使用 TongNCS 提供的 SpringBoot 开发工具包进行开发。
6	006_TongNCS_V2.0SpringCloud 开发手册	详细介绍 Java 研发人员使用 TongNCS 提供的 SpringCloud 开发工具包进行开发。
7	007_TongNCS_V2.0OpenAPI 使用手册	详细介绍 Java 研发人员使用 TongNCS 提供的 OpenAPI 开发工具进行开发。
8	008_TongNCS_V2.0OpenLDAP 认证使用手册	详细介绍 TongNCS 如何使用 OpenLDAP 进行用户认证以及 OpenLDAP 的安装与使用。

技术支持

东方通产品将为您提供全方位的技术支持，您可以通过以下方式获得技术支持：

- 网址：www.tongtech.com
- 电话：400-650-7088
- 邮箱：support@tongtech.com

您在取得技术支持时，请提供如下信息：

- 您的姓名
- 您的公司信息
- 您的联系方式
- 操作系统及其版本
- 产品版本号
- 日志等错误的详细信息

目录

声明	1
版本变更说明	2
前言	3
1. 使用前导读	6
2. 产品部署与启动	7
3. 运维安全	8
3.1. 修改默认登录密码、服务密钥	8
3.2. 修改 Token 过期时间	8
3.3. 开启鉴权	9
3.4. 设置角色权限	9
3.5. 修改 Server 集群内通讯密钥	11
3.6. 修改生成的 token 的密钥	11

1. 使用前导读

本章节针对 TongNCS 的安全配置，提供了基线详细配置方法和检查判断依据。

以下配置命令为示例，仅供参考。

2. 产品部署与启动

- 安全风险

在 Linux 操作系统上，root 作为超级用户，拥有执行所有指令，操作所有目录的权限。

尤其在生产环境下，一旦 root 账号被暴力破解或者因为误操作执行了恶意命令，会导致不可挽回的后果。

- 安全实施策略

尽量不使用 root 用户安装，禁止使用 root 用户启动服务。

- 若必须使用管理员权限，创建普通用户，遵循最小授权的原则，避免滥用 root 权限：

1. 以 root 账号登录，创建普通用户，如 tonguser。
2. vim /etc/sudoers

添加：tonguser ALL=(ALL) ALL

- 以普通用户，如 tongncs 用户，登录后进行安装。
- 以普通用户登录，启动服务。

- 影响

不以 root 启动服务，会导致 80 端口无法使用。

3. 运维安全

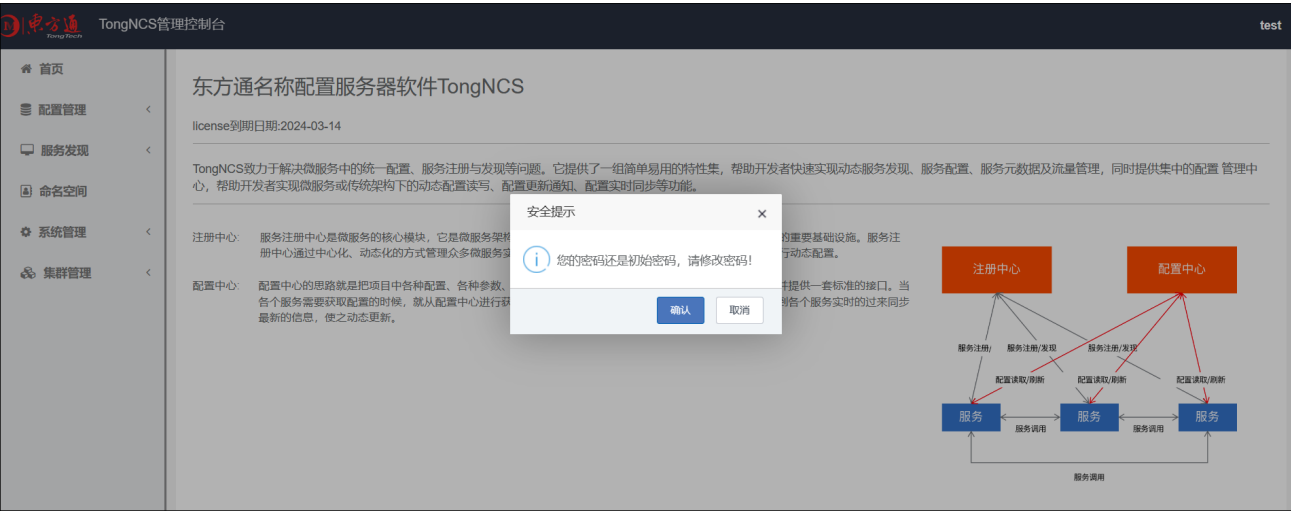
3.1. 修改默认登录密码、服务密钥

• 安全风险

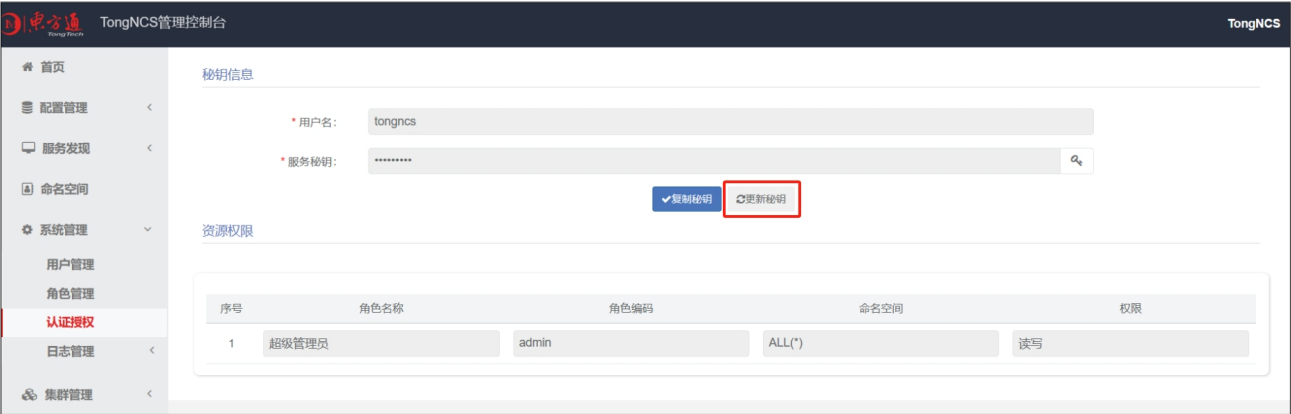
若不修改默认的账号密码和密钥，入侵者可通过默认密码和密钥非法轻易登录系统。

• 安全实施策略

首次登录控制台后，修改默认登录密码（建议不同于初始密码）。



修改服务密钥。



• 影响

无

3.2. 修改 Token 过期时间

• 安全风险

若 Token 过期时间过长，在访问界面长时间无人值守时，可能会被非法访问。

• 处理措施

server 修改 Token 过期时间

1. 修改配置文件: tongncs/conf/application.properties
2. 配置项: tongncs.core.auth.plugin.tongncs.token.expire.seconds

- 影响

无

3.3. 开启鉴权

- 安全风险

TongNCS 可采用鉴权与非鉴权两种模式运行, 为提升系统安全性, 建议开启鉴权。

- 处理措施

- 修改集群所有节点的配置文件: tongncs/conf/application.properties
- 修改配置: tongncs.core.auth.enabled、tongncs.core.auth.system.type

```
### The auth system to use, currently only 'tongncs' and 'ldap' is supported:
tongncs.core.auth.system.type=tongncs

### If turn on auth system:
tongncs.core.auth.enabled=true
```

- 影响

无

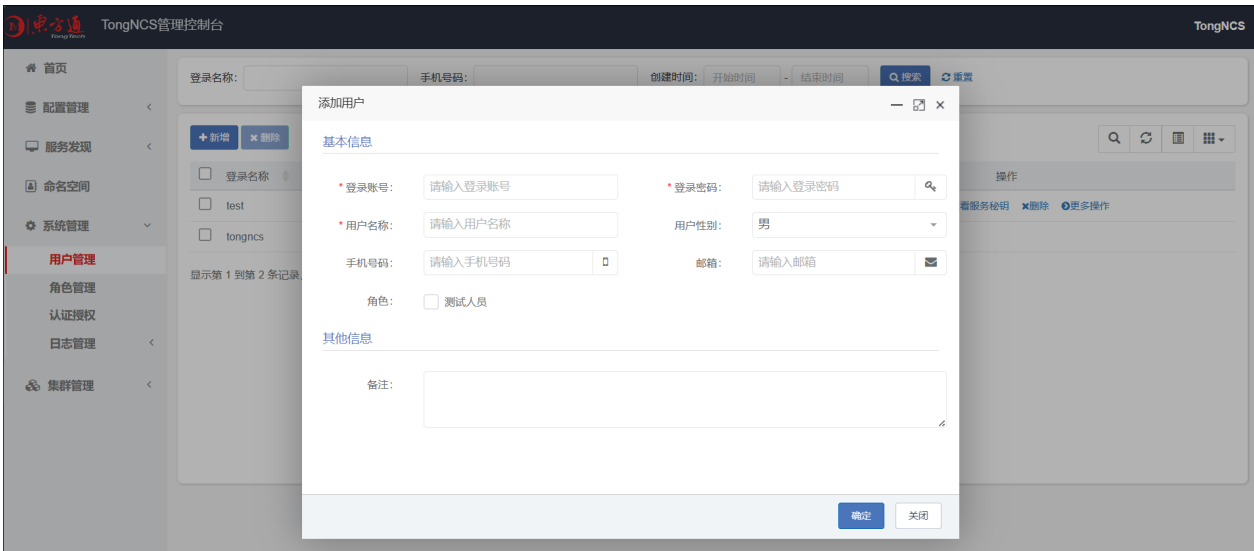
3.4. 设置角色权限

- 安全风险

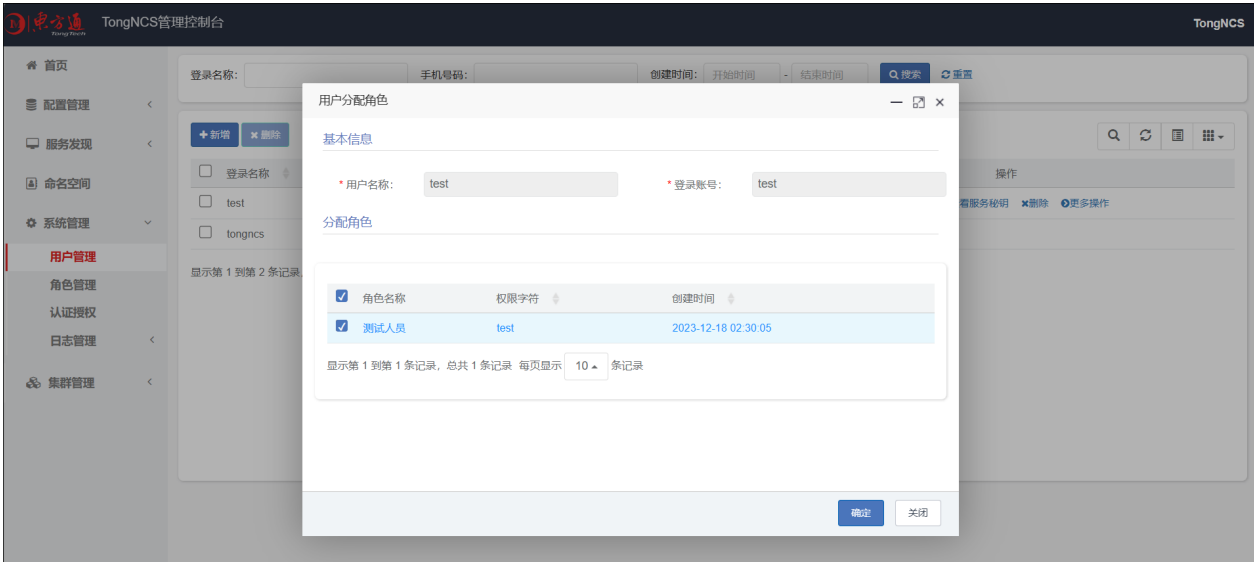
TongNCS 不同用户拥有不同角色, 不同角色拥有不同权限, 防止不同账户进行误操作。

- 处理措施

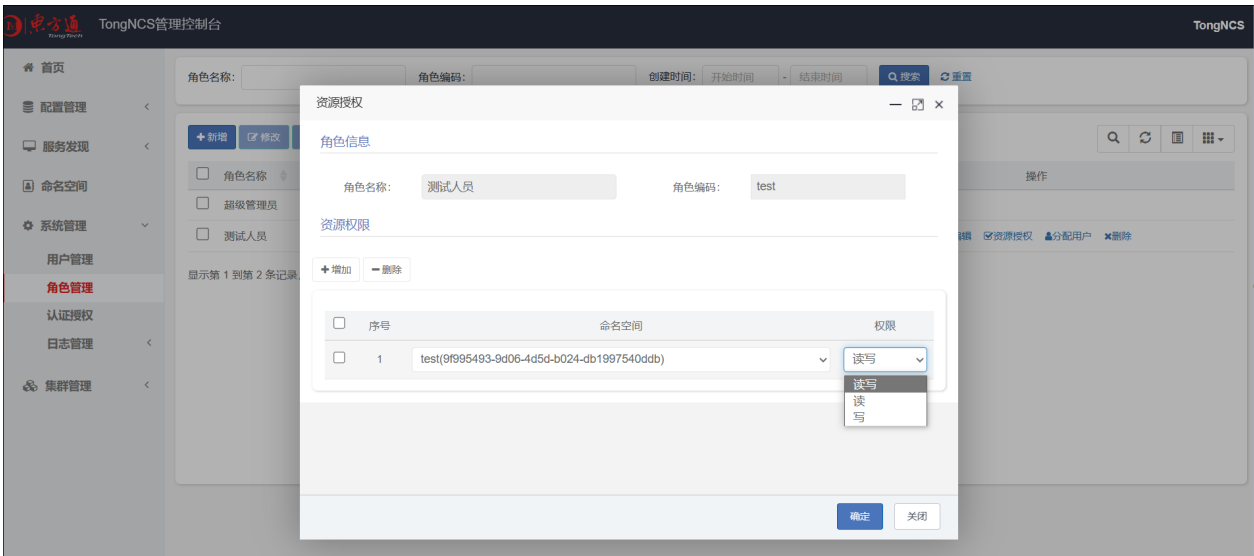
1. 使用 tongncs 用户登录系统, 并创建用户。



2. 给用户绑定角色。



3. 给角色授予命名空间权限（读、写）。



- 影响
- 无

3.5. 修改 Server 集群内通讯密钥

- 安全风险

TongNCS 集群间各节点通讯基于密钥鉴权，密钥泄漏会导致他人伪造密钥访问系统。

- 处理措施

修改集群所有节点的配置文件：tongncs/conf/application.properties

修改配置：tongncs.core.auth.server.identity.key、tongncs.core.auth.server.identity.value

```
### The two properties is the white list for auth and used by identity the request from other
tongncs.core.auth.server.identity.key=
tongncs.core.auth.server.identity.value=
```

- 影响

无

3.6. 修改生成的 token 的密钥

- 安全风险

TongNCS 基于此密钥生成登录 token，密钥泄漏后，会导致他人模拟生成用户 token，对系统进行访问。

- 处理措施

修改集群所有节点的配置文件：tongncs/conf/application.properties

修改配置：tongncs.core.auth.plugin.tongncs.token.secret.key

```
#💡 The default token (Base64 string):
tongncs.core.auth.plugin.tongncs.token.secret.key=
```

- 影响

无

